

Third-Party Vendor Risk Assessment

End-to-end assessment: tiering, due diligence, findings, scoring, treatment, and recommendation

Vendor	CloudPay Solutions, Inc. (fictional case study)
Service	Hosted payment processing and customer billing SaaS
Business owner	Finance & Customer Operations
Assessment type	Initial onboarding / pre-contract due diligence
Assessment date	July 27, 2026
Prepared by	Cybersecurity GRC / Third-Party Risk Management
Overall decision	CONDITIONAL APPROVAL - HIGH RESIDUAL RISK

Decision statement Proceed only after the mandatory pre-contract conditions in Section 10 are satisfied. Production data transfer and go-live are not authorized at this stage.

Document status

Field	Value
Version	1.0
Classification	Confidential
Assessment owner	Third-Party Risk Management
Review cycle	Annual, and upon material change or security incident
Next reassessment	Within 12 months of approval

1. Executive Summary

CloudPay Solutions was assessed as a prospective provider of a business-critical SaaS platform that will process payment information, customer personal data, and financial transaction records. The assessment covered inherent risk, vendor tiering, security and privacy due diligence, independent assurance evidence, contractual protections, identified control gaps, residual risk, and a risk-based onboarding recommendation.

Overall result Inherent risk: Critical (92/100). Control effectiveness: 72%. Residual risk: High (26/100). Recommendation: Conditional approval.

Key strengths

- Current SOC 2 Type II report with no qualified opinion and defined complementary user entity controls.
- Encryption at rest and in transit, strong identity controls, centralized logging, and 24/7 security monitoring.
- Documented incident response, vulnerability management, business continuity, and secure development processes.
- Cyber liability insurance and a formal privacy program with data subject request procedures.

Material concerns

- No contractually committed incident-notification time; the vendor's standard language allows notification without a fixed deadline.
- Critical vulnerabilities may remain open for up to 30 days, exceeding the organization's 15-day requirement.
- Subprocessor inventory does not include hosting regions and advance customer notification is limited.
- Recovery evidence supports a 12-hour recovery time, while the business requires 4 hours.
- Penetration-test evidence is a summary letter only, with no detailed remediation validation for medium findings.

Decision

Conditional approval is recommended because the vendor demonstrates a generally mature control environment, but several gaps materially affect incident response, resilience, vulnerability exposure, and fourth-party transparency. Contract signature may proceed only when the security addendum and data-processing agreement contain the mandatory conditions listed in Section 10. Production use must remain blocked until the designated pre-go-live conditions are evidenced and validated.

2. Scope, Assumptions, and Methodology

Assessment scope

- Security governance and compliance
- Identity and access management
- Data protection and privacy
- Network, endpoint, and cloud security
- Secure software development and change management
- Vulnerability management and penetration testing
- Security monitoring and incident response
- Business continuity and disaster recovery
- Fourth-party / subprocessor risk
- Contractual, legal, and insurance safeguards

Assumptions

- This is a fictional portfolio case study based on a typical critical SaaS onboarding.
- The vendor will process customer PII, tokenized payment data, and financial records but will not store full cardholder authentication data.
- The service is externally hosted and supports business-critical billing operations.
- Evidence was evaluated as if supplied through a controlled vendor due-diligence portal.

End-to-end workflow

1. Initiate the request and confirm business purpose, data flow, integrations, ownership, and criticality.
2. Calculate inherent risk and assign the vendor tier before considering controls.
3. Issue a risk-based questionnaire and request independent evidence.
4. Validate responses, identify exceptions, and test whether evidence is current and relevant.
5. Score control effectiveness and document findings using likelihood and impact.
6. Determine residual risk, define treatments, and obtain accountable risk acceptance where required.
7. Issue a recommendation with contracting, go-live, and monitoring conditions.
8. Track remediation and reassess annually or when a trigger event occurs.

3. Vendor Profile and Data Flow

Attribute	Assessment detail
Legal entity	CloudPay Solutions, Inc.
Service model	Multi-tenant SaaS hosted in a major public cloud
Business dependency	Customer billing, payment orchestration, invoice generation
Data handled	Customer names, addresses, email, account identifiers, tokenized payment data,

Attribute	Assessment detail
	invoice and transaction records
Data classification	Confidential / Restricted
Access method	API integration and administrative web portal
Privileged access	Vendor support and cloud operations personnel
Data residency	United States; subprocessor regions require confirmation
Estimated records	Approximately 1.5 million active and historical customer records
Service availability need	24x7; business RTO 4 hours, RPO 1 hour

Data flow summary

Customer and transaction data flows from the organization's applications through an authenticated API to CloudPay. CloudPay processes billing events, stores transaction and customer metadata, and returns status updates. Administrators access the management portal using federated identity. Approved subprocessors may support hosting, email delivery, monitoring, customer support, and backup services. Data is retained for seven years to support financial and regulatory requirements, then securely deleted.

4. Inherent Risk and Vendor Tiering

Inherent risk measures exposure before considering the vendor's safeguards. Each factor is scored from 1 (low) to 5 (critical) and weighted. The weighted score is converted to a 100-point scale.

Factor	Rating	Weight	Points	Rationale
Sensitive data volume	5	20%	20.0	PII and financial records at high volume
System / network access	4	15%	12.0	API connectivity and admin portal
Business criticality	5	20%	20.0	Billing disruption directly affects revenue
Regulatory / contractual impact	5	15%	15.0	Privacy, financial, and payment obligations
Availability dependency	5	15%	15.0	24x7 service; 4-hour business RTO
Fourth-party reliance	4	10%	8.0	Cloud and operational subprocessors
Geographic / concentration risk	2	5%	2.0	Primarily US-based processing

Inherent risk score 92/100 - Critical. Tier 1 / Critical Vendor.

Tier assignment

Tier	Score	Typical profile	Oversight
Tier 1 - Critical	80-100	Critical operations, sensitive data, broad access, or significant regulatory impact	Full assessment; annual review; continuous monitoring; executive approval
Tier 2 - High	60-79	Material data or operational dependency	Full or focused assessment; 12-18 month review
Tier 3 - Moderate	35-59	Limited sensitive data or moderate dependency	Standard questionnaire; 24-month review
Tier 4 - Low	0-34	No sensitive data and low operational impact	Basic due diligence; event-driven review

5. Evidence Reviewed

Evidence	Currency	Validation	Assessment note
SOC 2 Type II report	Current; 12-month period	Accepted with CUEC review	No qualification; three low exceptions remediated
ISO 27001 certificate	Current	Accepted	Scope includes SaaS platform and supporting cloud operations
Penetration test	Current-year summary letter	Partially accepted	Detailed report and retest evidence not provided
Vulnerability management policy	Current	Accepted with gap	Critical remediation SLA is 30 days
Incident response plan	Current	Accepted with gap	No fixed customer notification commitment
BCP/DR plan and test	Current-year	Partially accepted	Demonstrated 12-hour recovery vs. 4-hour need
Data flow and architecture	Current	Accepted	Logical flow and trust boundaries documented
Subprocessor list	Current	Partially accepted	Regions and advance-change notice incomplete
Cyber insurance certificate	Current	Accepted	\$10M aggregate coverage
Privacy policy / DPA	Current	Accepted with edits	Deletion, audit, and breach clauses require negotiation

6. Security and Privacy Questionnaire Assessment

Responses were scored as Effective (2), Partially Effective (1), or Ineffective / Not Evidenced (0). Not applicable items are excluded. Domain effectiveness equals points earned divided by maximum available points.

Domain	#	Control question	Vendor response	Evidence	Score
Governance	1	Security program approved and reviewed annually?	Yes	Policy suite; governance minutes	2
Governance	2	Independent assurance current and in scope?	Yes	SOC 2 Type II; ISO 27001	2
Governance	3	Security roles and accountability defined?	Yes	Organization chart; RACI	2
IAM	4	MFA enforced for privileged and remote access?	Yes	IAM standard; config screenshots	2
IAM	5	Access reviews performed at least quarterly?	Yes	Q1/Q2 review samples	2
IAM	6	Joiner-mover-leaver process time-bound?	Yes	HR/IAM procedure; tickets	2
IAM	7	Customer SSO and role-based access available?	Yes	SAML design; RBAC matrix	2
Data	8	Data encrypted in transit and at rest?	Yes	TLS 1.2+; AES-256 design	2
Data	9	Key management duties segregated?	Yes	KMS design and access review	2
Data	10	Retention and secure deletion defined?	Partial	Schedule; deletion procedure	1
Data	11	Data residency and processing locations transparent?	Partial	Architecture; subprocessor list	1
Privacy	12	Privacy impact assessments performed?	Yes	DPIA template and sample	2
Privacy	13	Data subject requests supported?	Yes	Procedure and SLA dashboard	2
Privacy	14	Breach notification contractually time-bound?	No	Standard DPA	0
Cloud/Network	15	Network segmentation and tenant isolation tested?	Yes	Architecture; SOC controls	2
Cloud/Network	16	Secure configuration baselines enforced?	Yes	CIS-aligned standard; CSPM report	2
Cloud/Network	17	Endpoint protection covers production admin assets?	Yes	EDR coverage report	2
SDLC	18	Security requirements integrated into SDLC?	Yes	SDLC standard; release checklist	2
SDLC	19	SAST, DAST, dependency and secret scanning used?	Yes	Pipeline evidence	2
SDLC	20	High-risk changes independently approved?	Yes	Change samples	2
Vulnerability	21	Critical vulnerabilities remediated within 15 days?	No	Policy states 30 days	0
Vulnerability	22	External penetration test performed annually?	Partial	Executive summary only	1
Vulnerability	23	Internet-facing assets continuously scanned?	Yes	Scanner dashboard	2
Monitoring	24	Central logs protected and monitored 24x7?	Yes	SIEM design; SOC schedule	2
Monitoring	25	Alert use cases reviewed and tested?	Yes	Quarterly tuning records	2
Incident	26	Incident plan exercised at least annually?	Yes	Tabletop report	2

Domain	#	Control question	Vendor response	Evidence	Score
Incident	27	Customer communication procedures tested?	Partial	Procedure, no notification SLA	1
Resilience	28	Recovery capability meets 4-hour RTO / 1-hour RPO?	No	DR test: RTO 12h; RPO 1h	0
Resilience	29	Backups encrypted, immutable, and restoration-tested?	Yes	Backup standard; test results	2
Fourth party	30	Subprocessors risk-assessed before use?	Yes	TPRM procedure; samples	2
Fourth party	31	Advance notice and location transparency provided?	Partial	List lacks regions; 10-day notice	1
Physical	32	Physical security inherited from validated data centers?	Yes	Cloud provider assurance	2
HR Security	33	Screening, NDA, and annual training implemented?	Yes	HR policy; training metrics	2
Contract	34	Audit, deletion, incident, and termination rights adequate?	Partial	Standard agreement requires edits	1
Insurance	35	Cyber insurance adequate and current?	Yes	\$10M certificate	2

Domain scorecard

Domain	Points	Effectiveness	Rating
Governance & assurance	6/6	100%	Effective
Identity & access	8/8	100%	Effective
Data protection	6/8	75%	Partially effective
Privacy	4/6	67%	Partially effective
Cloud / network / endpoint	6/6	100%	Effective
Secure development	6/6	100%	Effective
Vulnerability management	3/6	50%	Needs improvement
Monitoring & incident response	7/8	88%	Effective
Resilience	2/4	50%	Needs improvement
Fourth-party risk	3/4	75%	Partially effective
Physical & personnel	4/4	100%	Effective
Contract & insurance	3/4	75%	Partially effective

Control effectiveness 51 points earned out of 70 available = 72.9% (rounded to 72% for residual-risk calculation).

7. Findings and Risk Scoring

Finding risk is calculated as Likelihood x Impact using a 5x5 matrix. Scores of 20-25 are Critical, 12-19 High, 6-11 Moderate, and 1-5 Low. Residual ratings reflect existing safeguards and proposed treatment.

ID	Finding	Domain	L	I	Inherent	Required treatment	Target residual
F-01	No fixed breach-notification deadline	Incident / Contract	4	5	20 Critical	Contract: notify within 24 hours of confirmed incident; immediate notice for material events	8 Moderate
F-02	Critical vulnerability SLA is 30 days	Vulnerability	4	4	16 High	15-day SLA; 72-hour containment for actively exploited issues; monthly metrics	8 Moderate
F-03	DR recovery misses 4-hour business RTO	Resilience	4	5	20 Critical	Validated 4-hour recovery plan and test before go-live, or approved business workaround	10 Moderate
F-04	Subprocessor locations and notice incomplete	Fourth party / Privacy	3	4	12 High	Full list with regions; 30-day advance notice and objection right	6 Moderate
F-05	Penetration-test detail and retest evidence limited	Assurance	3	4	12 High	Provide sanitized detailed report and closure evidence for high/medium items	4 Low
F-06	Deletion evidence not independently validated	Data lifecycle	3	3	9 Moderate	Annual deletion attestation and sample evidence; contract deletion certificate	4 Low
F-07	Customer communication exercise incomplete	Incident	3	3	9 Moderate	Include customer notification scenario in next tabletop; share after-action evidence	4 Low
F-08	Standard contract limits customer audit rights	Contract	3	4	12 High	Right to review assurance evidence and conduct audit following material incident	6 Moderate

Risk matrix

Likelihood / Impact	1	2	3	4	5
5 - Almost certain	5 L	10 M	15 H	20 C	25 C
4 - Likely	4 L	8 M	12 H	16 H	20 C
3 - Possible	3 L	6 M	9 M	12 H	15 H
2 - Unlikely	2 L	4 L	6 M	8 M	10 M
1 - Rare	1 L	2 L	3 L	4 L	5 L

8. Overall Residual Risk

The overall residual score uses the inherent-risk score adjusted by demonstrated control effectiveness. This model is a governance aid and does not replace accountable risk judgment.

Measure	Result	Interpretation
Inherent risk	92/100	Critical exposure before controls
Control effectiveness	72%	51 of 70 questionnaire points
Residual-risk calculation	$92 \times (1 - 0.72)$	25.76
Rounded residual score	26/100	High

Residual risk conclusion HIGH. The score is near the Moderate boundary, but risk judgment remains High because two critical scenarios - breach notification and service recovery - could cause material harm before compensating measures are validated.

Residual rating	Score	Required governance action
Critical	50-100	Do not onboard without executive exception and immediate treatment
High	25-49	Conditional approval only; time-bound remediation and senior acceptance
Moderate	10-24	Approve with tracked remediation and routine monitoring
Low	0-9	Approve; standard monitoring

9. Risk Treatment and Remediation Plan

Finding	Treatment	Action	Owner	Due	Status
F-01	Mitigate / Transfer	Execute security addendum with 24-hour notification and cooperation obligations	Legal	Before contract	Open - blocking
F-03	Mitigate / Avoid	Evidence tested 4-hour recovery or approve documented fallback before production	BCM & Business	Before go-live	Open - blocking
F-02	Mitigate	Adopt 15-day critical SLA and 72-hour exploit containment; report monthly	Vendor CISO	60 days	Open
F-04	Mitigate	Provide complete subprocessor register, regions, and 30-day change notice	Privacy / Legal	Before contract	Open - blocking
F-05	Mitigate	Provide sanitized detailed penetration test and retest evidence	Vendor Security	Before go-live	Open - blocking

Findin g	Treatment	Action	Owner	Due	Status
F-08	Transfer / Mitigate	Negotiate audit and assurance-review rights	Legal	Before contract	Open - blocking
F-06	Mitigate	Add deletion certificate and annual deletion attestation	Data Owner	90 days	Open
F-07	Mitigate	Run customer-notification tabletop and provide after-action report	Incident Mgmt	180 days	Open

Acceptance authority

Any remaining High residual risk requires written acceptance by the business executive and CISO, with concurrence from Legal and Privacy where contractual or personal-data exposure remains. Critical residual risk may not be accepted under the standard onboarding process and must be escalated to the enterprise risk committee.

10. Final Recommendation

Recommendation CONDITIONAL APPROVAL - DO NOT AUTHORIZE PRODUCTION USE YET.

CloudPay may proceed to contract finalization because its core security program is generally mature and independently assessed. However, its current risk posture does not support unconditional onboarding. Approval is conditioned on the following controls and evidence.

Mandatory before contract signature

- Execute a security addendum requiring notification within 24 hours of a confirmed security incident affecting organizational data or services.
- Execute a data-processing agreement covering processing purpose, confidentiality, deletion/return, audit cooperation, cross-border processing, and subprocessor obligations.
- Obtain a complete subprocessor register with processing purpose and location, plus at least 30 days' advance notice of material changes.
- Include reasonable assurance-review and incident-triggered audit rights.
- Confirm minimum cyber liability coverage of \$10 million and annual evidence of renewal.

Mandatory before production go-live

- Validate a recovery strategy capable of meeting the 4-hour RTO and 1-hour RPO, or obtain an approved business continuity exception with a tested workaround.
- Receive a sanitized detailed penetration-test report and evidence that all Critical and High findings are closed; unresolved Medium findings must have approved plans.

- Confirm the 15-day Critical vulnerability remediation commitment and 72-hour containment for actively exploited vulnerabilities.
- Complete SSO/MFA integration, least-privilege role design, administrator access review, and logging integration.
- Verify data minimization, retention configuration, deletion workflow, and secure API configuration in the implementation environment.

Post-go-live conditions

- Monthly reporting for critical/high vulnerabilities and security incidents for the first six months.
- Quarterly service availability and recovery performance review.
- Annual SOC 2, penetration-test, insurance, subprocessor, privacy, and resilience evidence refresh.
- Immediate reassessment following a material incident, acquisition, major hosting change, adverse regulatory event, or significant control deterioration.

Required approvals

Approver	Accountability	Status
Business owner	Accept business dependency and fund required continuity measures	Pending
Information Security / CISO	Approve security residual risk and remediation plan	Pending
Privacy	Approve processing, residency, DPA, and subprocessor terms	Pending
Legal	Confirm required contractual protections are executed	Pending
Procurement / TPRM	Confirm all blocking conditions and evidence are complete	Pending

11. Ongoing Monitoring Plan

Frequency	Monitoring activity	Owner	Escalation
Continuous	External attack-surface, breach, sanctions, adverse media, financial-health alerts	TPRM / Security	Material alert triggers review
Monthly - first 6 months	Open Critical/High vulnerabilities, incidents, uptime, remediation status	Vendor manager	Missed SLA triggers escalation
Quarterly	Availability, DR capability, privileged access, major changes, subprocessor changes	Business / Security	Trend deterioration triggers CAP
Annually	SOC 2, ISO scope, penetration test, insurance, BCP/DR test, privacy and subprocessor evidence	TPRM	Full Tier 1 reassessment
Event-driven	Incident, acquisition, data/location change, new integration, material control failure	TPRM / Risk	Immediate reassessment

Key risk indicators

- Any confirmed data breach or material service incident.
- Critical vulnerability older than 15 days or actively exploited issue not contained within 72 hours.
- Monthly availability below 99.9% or recurring severity-1 incidents.
- Failed recovery exercise or recovery time greater than 4 hours.
- Material SOC 2 qualification, lapsed certification, or overdue penetration test.
- Unapproved subprocessor or processing-location change.
- Material decline in financial condition or cyber insurance coverage.

Appendix A - Scoring Methodology

Element	Method
Question score	2 = Effective; 1 = Partially Effective; 0 = Ineffective / Not Evidenced
Domain effectiveness	Points earned / available points
Likelihood	1 Rare; 2 Unlikely; 3 Possible; 4 Likely; 5 Almost certain
Impact	1 Insignificant; 2 Minor; 3 Moderate; 4 Major; 5 Severe
Finding risk	Likelihood x Impact
Overall residual risk	Inherent score x (1 - control effectiveness)
Risk judgment overlay	Critical scenarios, concentration, evidence quality, and risk appetite may raise the calculated rating

Appendix B - Evidence Request List

- Current SOC 2 Type II report and bridge letter
- ISO 27001 certificate and statement of applicability
- Security, privacy, access control, encryption, vulnerability, incident, and BCP/DR policies
- Current penetration-test report and remediation/retest evidence
- Architecture and data-flow diagrams, asset inventory, and data residency statement
- Access-review samples, MFA coverage, security-training metrics, and vulnerability dashboards
- Most recent BCP/DR test report and restoration-test evidence
- Subprocessor register and third-party risk procedure
- Data retention/deletion standard and deletion attestation
- Cyber liability insurance certificate
- Standard MSA, DPA, SLA, security addendum, and incident-notification terms

Appendix C - Assessor Checklist

Assessment gate	Status
Vendor intake and ownership confirmed	Completed
Data flow and classification validated	Completed
Inherent risk and tier approved	Completed
Questionnaire and evidence reviewed	Completed
Findings logged and owners assigned	Completed
Legal / privacy clauses negotiated	Pending
Blocking evidence validated	Pending
Residual risk acceptance obtained	Pending
Monitoring schedule established	Pending

End of assessment